LAB - DAY 5

Higher National Diploma in Network Engineering, Year 2
BSc (Hons) Ethical Hacking & Network Security, Year 2

Accounts, permissions and a hardened baseline



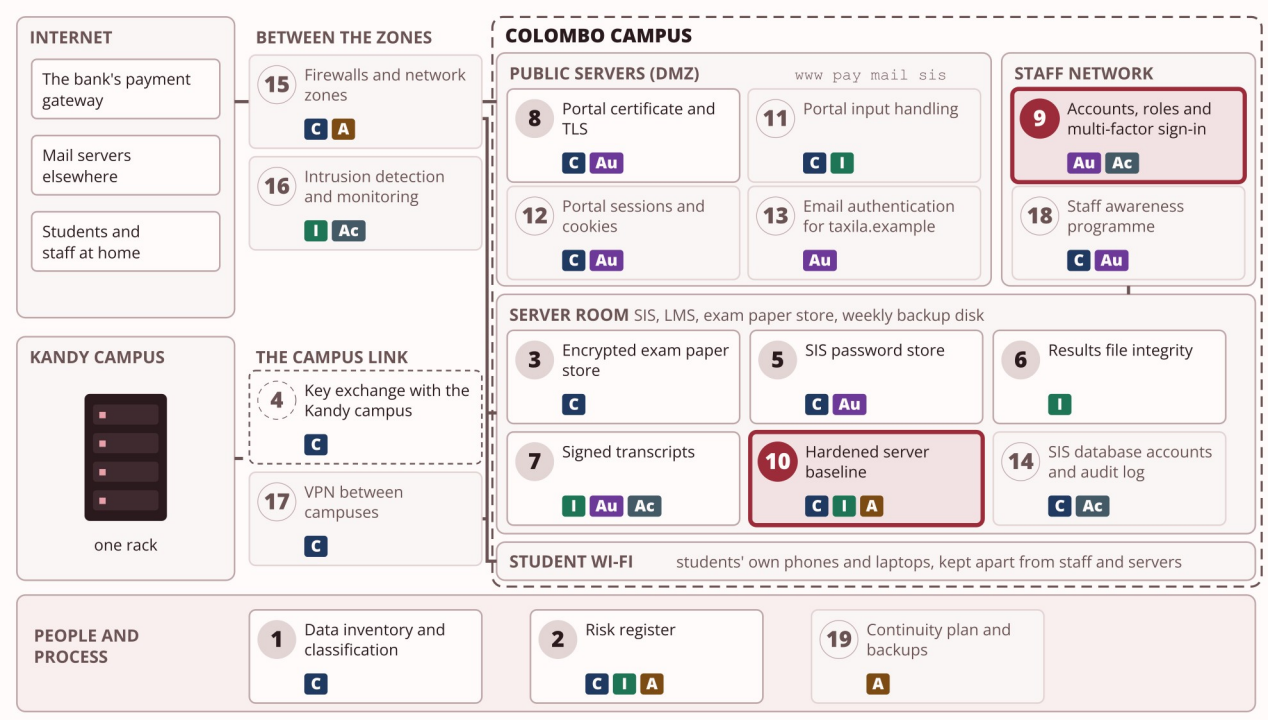
Adds to the register: **9** **10**

Floor tier: every step

Full tier: recommended

Niranga Dharmaratna
School of Computing & Engineering
National Institute of Business Management

The security register



TODAY

9 Accounts, roles and multi-factor sign-in

10 Hardened server baseline

KEY

- Added today
- Added earlier
- Concept only
- Not yet added

IT

HEAD OF IT

Tell me what you turned off, and what it broke. If the answer is nothing, it should never have been running.

The Head of IT, at the start of the lab.

Your personal findings

```
# chosen from the SHA-256 digest of your index
F1  a service: ssh, apache2 or mariadb, with its port
F2  a file with mode 666, and its safe mode
F3  logging off: the journal keeps nothing
F4  updates waiting: read only, not installed today
F5  your lecturer account, lec and four characters
```

Your findings differ from your neighbour's. A copied report names the wrong service, file or account.

SEGMENT 1 - 40 MIN

Read the baseline audit

Both tiers

Make your baseline and audit it

1

Make your baseline from your own index.

Expected: Five findings, F1 to F5.

Floor path: `hardening-checklist`: Your baseline report.

2

Audit the server; find your file and your service.

Expected: Your file shows `[ SUGGESTION ]`; a hardening index.

Floor path: The report panel's audit excerpt.

3

Sort F1 to F4 into the five hardening areas.

Expected: Services, permissions, logging, patching.

The same on the full tier

```
$ sudo python3 seed-baseline.py COHNDNE999X000
$ sudo lynis audit system
    File: /etc/crontab                    [ SUGGESTION ]
$ apt list --upgradable
```

Take the `day-5-start` snapshot first. The script weakens only the machine it runs on, and refuses to run on anything but Kali.

SEGMENT 2 - 55 MIN

Fix your personal findings

Both tiers

Fix your three findings

4 Disable your service now and at boot.

Expected: `disabled`; its port gone from `ss`.

5 Give your file its safe mode.

Expected: `stat` prints `600` or `644`.

6 Remove the setting; restart the journal.

Expected: New journal lines appear.

```
$ sudo systemctl disable --now apache2
$ sudo chmod 600 /etc/crontab
$ sudo rm /etc/systemd/journald.conf.d/50-day5-baseline.conf
$ sudo systemctl restart systemd-journald
$ sudo journalctl -n 3 --no-pager
```

Re-audit and check

7 Audit again, then run the script's check.

Expected: Your file `[ OK ]`; F1 to F3 `FIXED`.

Floor path: The panel shows F1 to F3 fixed; score 52 to 83.

```
$ sudo lynis audit system
$ sudo python3 seed-baseline.py --check COHNDNE999X000
F1  FIXED  apache2 is disabled and inactive
F2  FIXED  /etc/crontab has mode 600, safe mode 600
F3  FIXED  the journal setting Storage=none is gone
```

The hardening index may move a few points either way. The proof is the lines that cleared, not the number.

SEGMENT 3 - 30 MIN

Account and role design

Both tiers

Design the roles

8 Fill in `role-table.csv`: lecturer role and student role.

Expected: The student role reads only its own record.

9 Name the action that needs a second approver.

Expected: Changing a released grade: lecturer asks, Registrar approves.

```
# full tier: your lecturer account holds no administrator rights
$ id lecb99b
$ groups lecb99b
```

Design the permissions from the job first. Then assign people to roles.



DATA PROTECTION OFFICER

Whose data is this, and how would we know if someone read it who should not?

The Data Protection Officer, reading your role table.

SEGMENT 4 - 25 MIN

Prove it, break it, reset and write up

Both tiers

Prove it, then break it

PROVE IT

- Your seeded findings each **fixed**, with the fix named
- The student role reads only its own record
- The recompute tool derives the same findings

× BREAK IT

- `access-models`: give the student role read all records
- `student01` can read every grade
- Revoke it; write symptom, cause and fix

Reset, and the rules

RESET

- Copy your evidence first
- Full tier: restore the `day-5-start` snapshot
- No snapshot: run the script with `--undo`

RULES OF ENGAGEMENT

- No tool in this lab can affect anyone else's system
- You harden only your own virtual machine, or mark up the report

Record your evidence

EVIDENCE

- Each value goes in the template's table, with the step it comes from
- Form your group of four and agree its roles before you leave
- Your addressed findings, each with its fix
- Your least-privilege role table
- The hand-drawn AAA sketch
- Your 120-word explanation

Questions & Discussion

Next: Day 6, web applications and their fixes.



Disclaimer & Copyright

The information in this presentation is for general teaching purposes only. It is not comprehensive and is not professional advice; any reliance you place on it is at your own risk. I aim to keep it accurate, but I make no representations or warranties of any kind about its completeness, accuracy, reliability or suitability.

Security tools, standards and laws change. Versions, editions and commencement dates in this presentation were checked at the time of writing; check the current documentation before relying on them.

This presentation may refer to third-party websites or content. I do not endorse their views or information, and I am not responsible for their content.

Taxila College is fictional. Its campuses, people, systems and incidents were invented for teaching. Product and tool names, for example Kali Linux, VirtualBox, CyberChef and Wireshark, belong to their owners; this material is not affiliated with or endorsed by any of them.

Practise only on your own virtual machine, the module's provided files and application, and the portal's demos. Testing a system you do not own, without written permission, is an offence under Sri Lanka's Computer Crime Act, No. 24 of 2007.

© Niranga Dharmaratna, School of Computing & Engineering, National Institute of Business Management. Teaching content under CC BY-NC-SA 4.0; code and demonstrations under MIT; Open Sans under the SIL Open Font Licence.

Revision f16eef3